

TBox 安全服务产品说明书

基于独立安全芯片的密钥管理与密码学运算系统

安全芯片 华大 CIU98B | 架构 HSM ENGINE + paho 回调注入

版本: v1.0 | 日期: 2026-07-22

适用范围: 基于独立 HSM 安全芯片的 TBox 车联网终端

目录

第一章：产品概述

1.1 产品定义 | 1.2 核心价值 | 1.3 产品组件全景图

第二章：安全架构

2.1 安全芯片架构 | 2.2 密钥安全边界 | 2.3 SDK 软件栈

第三章：应用场景

3.1 场景总览 | 3.2 HTTPS 双向认证 | 3.3 MQTTS 双向认证

第四章：产线灌装

4.1 灌装流程 | 4.2 证书签发 | 4.3 安全约束

第五章：开发集成

5.1 SDK 组成 | 5.2 HTTPS 集成 | 5.3 MQTTS 集成

第六章：运维与恢复

第七章：安全与合规

附录：技术指标与术语

第一章：产品概述

1.1 产品定义

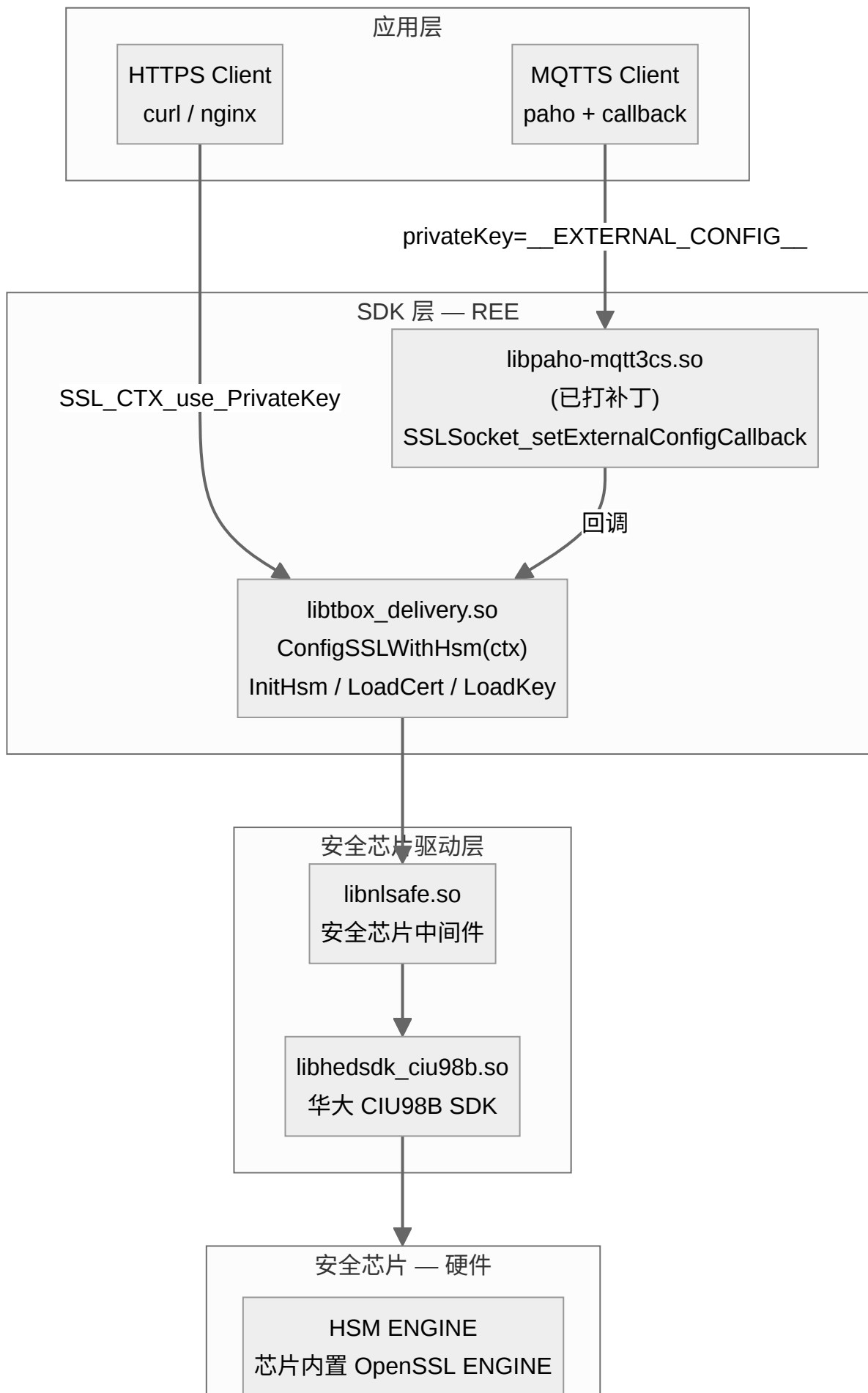
TBox 安全服务在设备主板上搭载一颗独立安全芯片（华大 CIU98B），通过芯片厂商 SDK 和自研交付库（libtbox_delivery.so）为上层应用提供以下核心安全能力：

- **密钥安全存储**：设备 RSA 私钥、证书、CA 链在芯片出厂时烧录，明文永不出芯片
- **密码学运算**：RSA 签名/验签、PKCS#1 解密等操作在安全芯片内部完成
- **TLS 双向认证**：通过 HSM ENGINE + paho 回调注入将密钥操作接入 HTTPS 和 MQTTS 协议栈
- **产线一机一密**：每台设备的密钥和证书在芯片封测阶段烧录，工厂灌装仅做 PIN 设置和检查

1.2 核心价值

价值	说明
密钥不出安全芯片	私钥在安全芯片内生成和存储，全生命周期不离开芯片物理边界
标准协议兼容	通过 OpenSSL HSM ENGINE + paho 回调注入，应用层无需适配
硬件信任根	安全芯片自带真随机数发生器 (TRNG) 和防篡改保护
一机一密	每台设备芯片内烧录唯一密钥，设备身份可认证、可追溯
车规级	安全芯片通过 AEC-Q100 认证，支持 -40°C ~ 105°C 工作温度

1.3 产品组件全景图



芯片内存储

kDevicePrivateRsaKey

kDevicePrivateRsaCert

kCA / kSubCert

硬件密码学引擎

RSA / AES / SM2

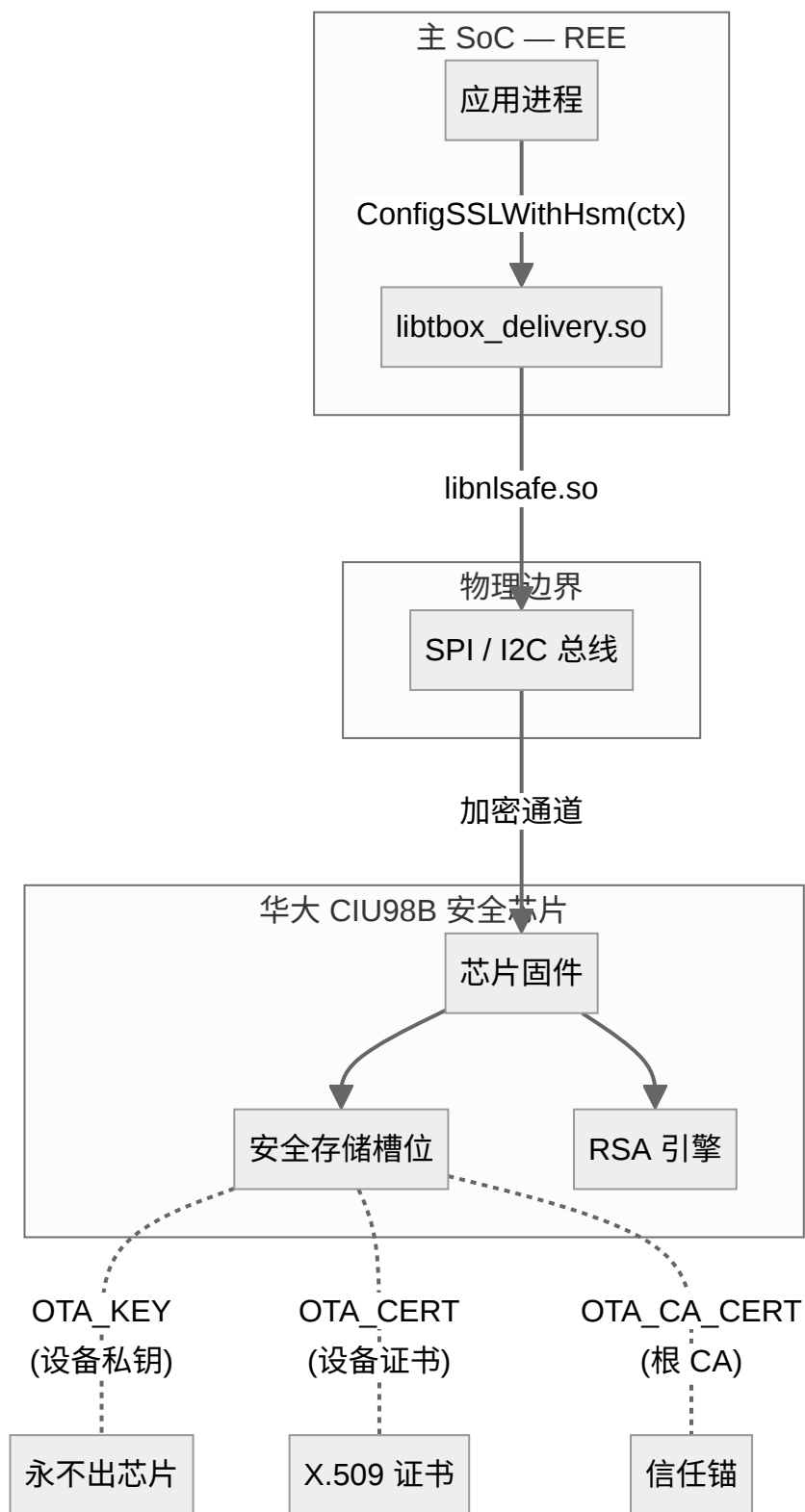
第二章：安全架构

2.1 安全芯片架构

华大 CIU98B 安全芯片通过 SPI/I2C 总线与主 SoC 连接。芯片内部运行独立的固件，对外暴露 PKCS#11 风格的安全存储槽位和 HSM ENGINE 接口。

	主 SoC (REE)	安全芯片 (HSM)
处理器	ARM Cortex-A / M 应用核心	专用安全控制器
操作系统	Linux	芯片固件
密钥可见性	仅公钥	完整密钥材料
物理防护	无	防篡改 + 侧信道防护
通信接口	—	SPI / I2C

2.2 密钥安全边界



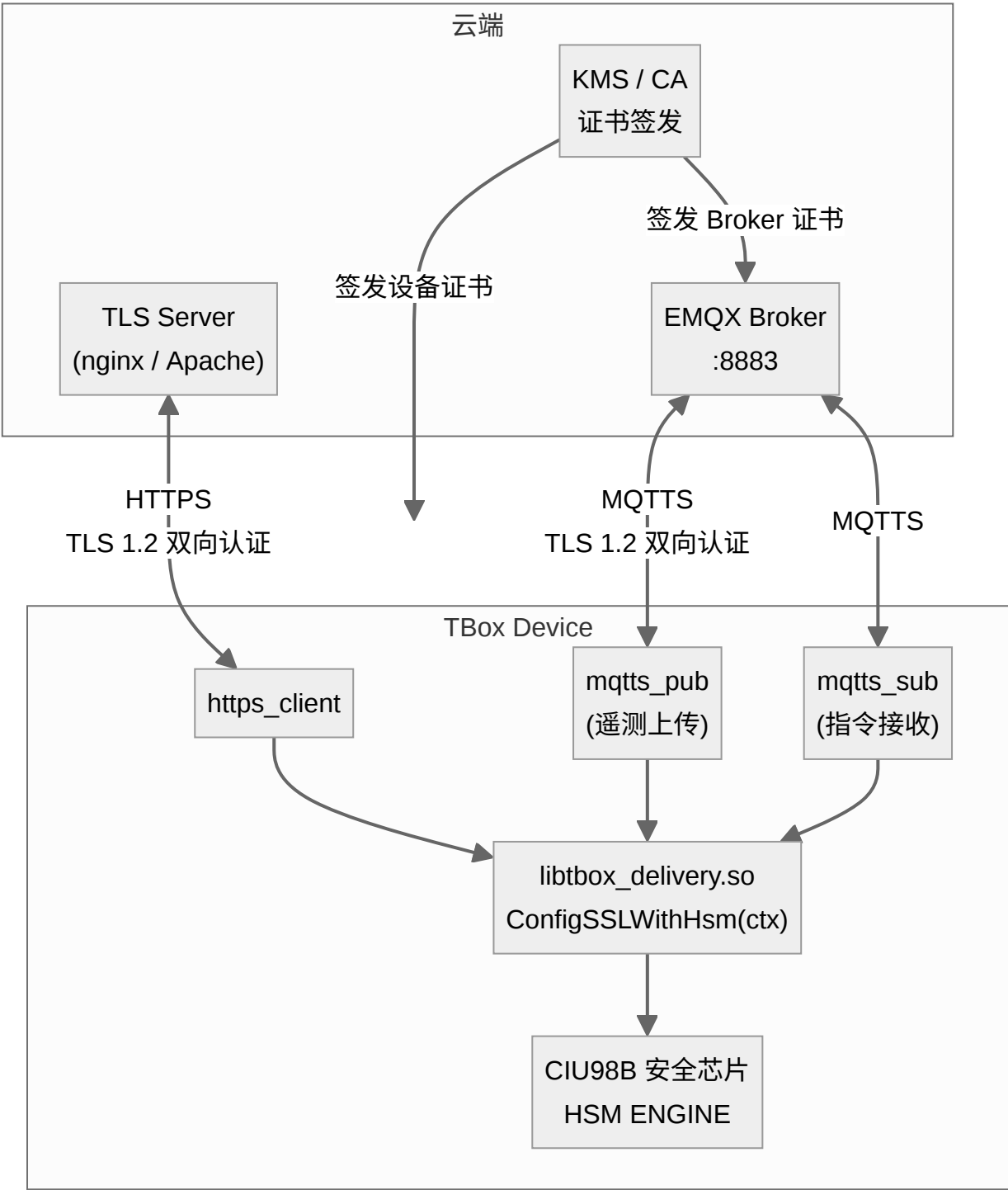
2.3 SDK 软件栈



应用只需 `#include <tbx/UtilForHsm.h>` 并链接 `libtbx_delivery.so`。NL 系列中间件和芯片驱动由设备镜像预装，应用无需感知。

第三章：应用场景

3.1 场景总览



3.2 HTTPS 双向认证

应用通过 `ConfigSSLWithHsm(ctx)` 一次性注入芯片凭据，之后 TLS 握手中的私钥操作由 HSM ENGINE 在安全芯片内部完成：


```

SSL_CTX *ctx = SSL_CTX_new(TLS_client_method());
InitHsm(); // 初始化安全芯片 + 加载 HSM ENGINE
ConfigSSLWithHsm(ctx); // 注入设备证书 / 私钥(ENGINE引用) / CA 链
SSL *ssl = SSL_new(ctx);
SSL_connect(ssl); // TLS 握手 - 签名在芯片内完成

```

3.3 MQTTS 双向认证

paho.mqtt.c 库通过补丁（`SSLSocket_setExternalConfigCallback`）支持外部 SSL 配置注入，回调中调用 `ConfigSSLWithHsm`：

```

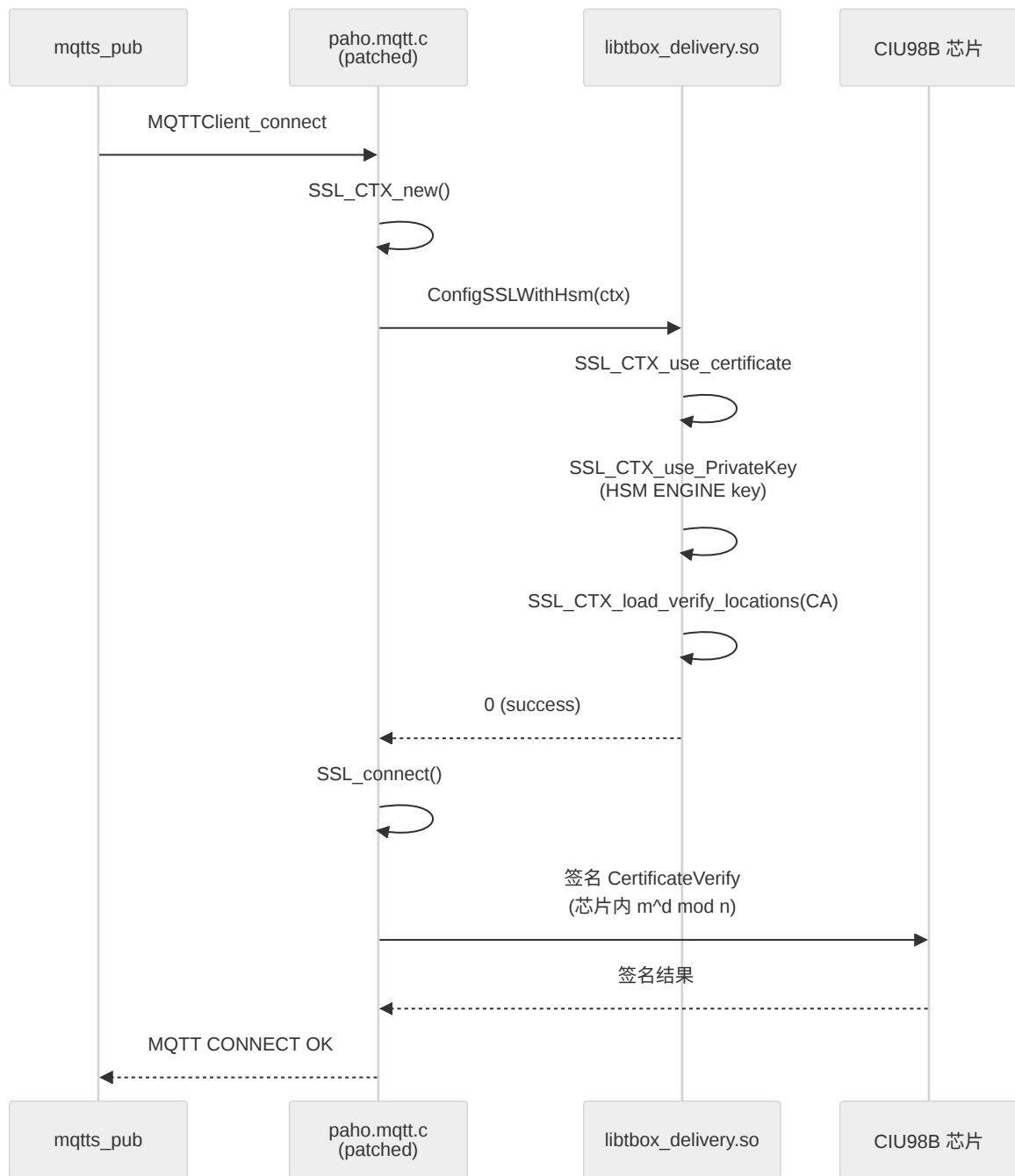
InitHsm();
SSLSocket_setExternalConfigCallback(ConfigSSLWithHsm);

MQTTClient_create(&client, "ssl://broker:8883", "tbox-device", ...);

ssl_opts.privateKey = "__EXTERNAL_CONFIG__"; // 触发 paho 回调
MQTTClient_connect(client, &conn_opts); // 回调中注入 HSM 凭据

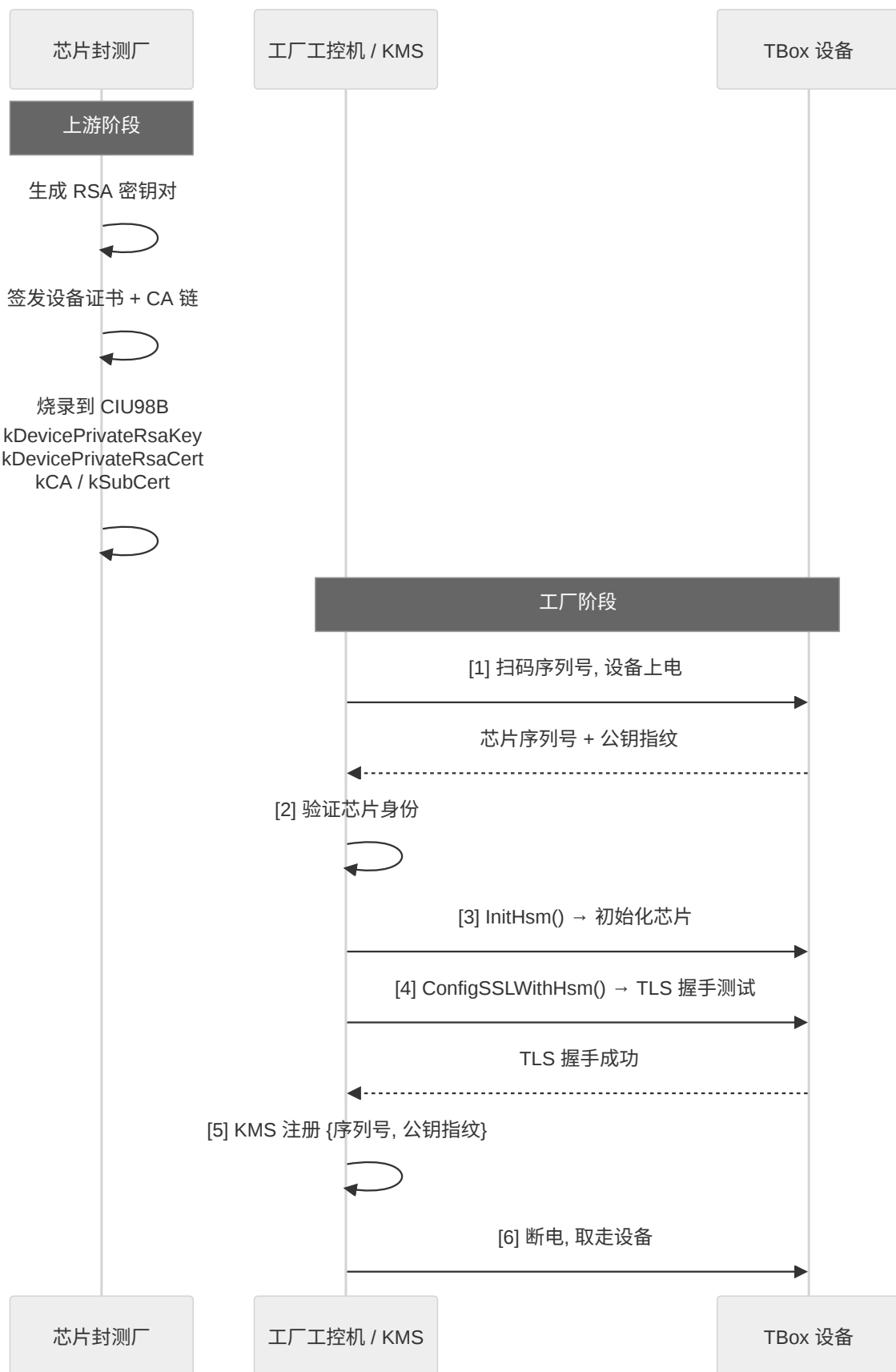
MQTTClient_publishMessage(client, topic, &msg, &token);
MQTTClient_subscribe(client, topic, 1);

```



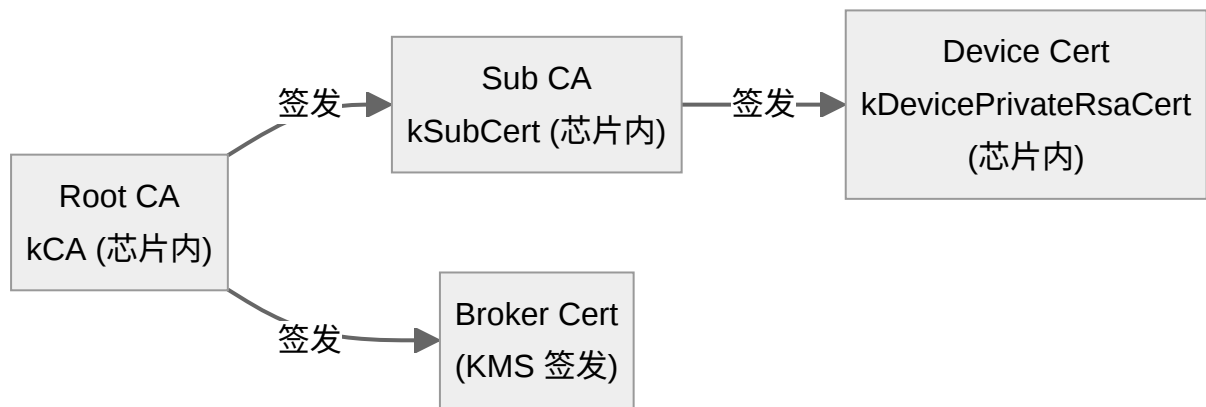
第四章：产线灌装

4.1 灌装流程



与 OP-TEE 方案的关键区别：密钥在芯片封测阶段烧录，工厂灌装仅做身份验证和功能测试。单台耗时约 5-8 秒。

4.2 证书体系



设备自带 Root CA → Sub CA → Device Cert 的完整信任链。Broker 证书由同一 Root CA 签发，设备侧验证 Broker 时只需信任 kCA 即可。

4.3 安全约束

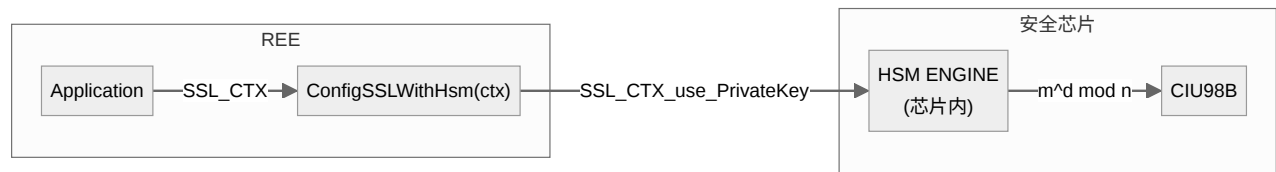
约束	措施
密钥烧录	在芯片封测厂的洁净室环境完成，离线操作
芯片身份	每颗芯片有唯一序列号，KMS 中登记
物理安全	安全芯片自带防篡改保护，开盖自毁密钥
导出限制	HSM ENGINE 设计上禁止导出明文私钥
审计日志	芯片初始化 + 功能验证记录写入工厂 MES

第五章：开发集成

5.1 SDK 组成

组件	文件	用途
交付库	libtbox_delivery.so	InitHsm + ConfigSSLWithHsm + 证书读取
公共库	librouter_common.so	delivery 库的直接依赖，随 SDK 分发
HSM 中间件	libnlSAFE.so	芯片驱动，设备镜像预装
	libhedsdk_ciu98b.so	
paho (补丁版)	libpaho-mqtt3cs.so	带 SSLSocket_setExternalConfigCallback 补丁
头文件	tbox/UtlForHsm.h	InitHsm / ConfigSSLWithHsm / 回调声明
	paho/SSLSocket.h	

5.2 HTTPS 集成



```
InitHsm();
SSL_CTX *ctx = SSL_CTX_new(TLS_client_method());
ConfigSSLWithHsm(ctx);
SSL_CTX_use_certificate_file(ctx, "device.crt", SSL_FILETYPE_PEM);
// TLS 握手 - 私钥操作在芯片内完成
```

5.3 MQTTS 集成

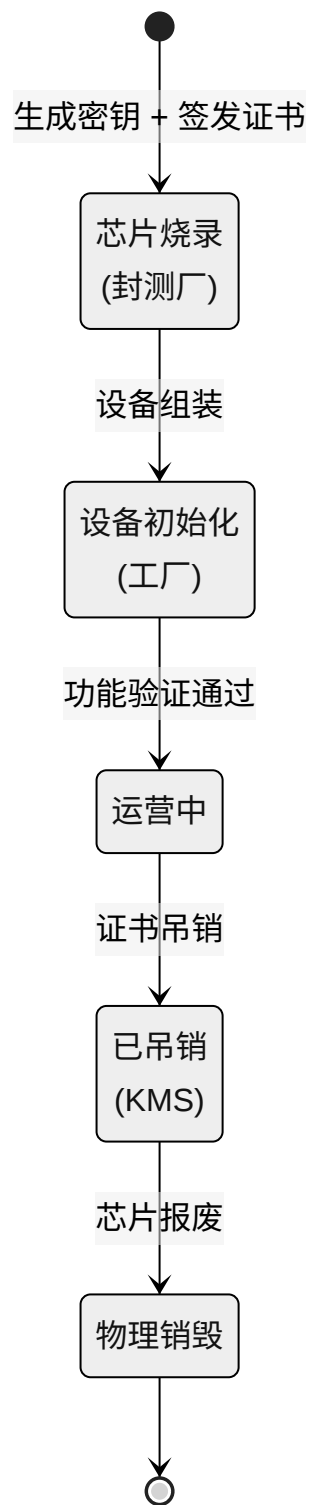


```
InitHsm();
SSLSocket_setExternalConfigCallback(ConfigSSLWithHsm);

MQTTClient_create(&client, "ssl://broker:8883", "tbox-device", ...);
ssl_opts.privateKey = "__EXTERNAL_CONFIG__"; // 触发回调
MQTTClient_connect(client, &conn_opts); // paho 调 ConfigSSLWithHsm
MQTTClient_publishMessage(client, topic, &msg, &token);
```

第六章：运维与恢复

6.1 密钥生命周期



与 OP-TEE 方案的关键区别：密钥不可在设备端生成或删除，更新只能通过更换芯片或 OTA 更新证书（不换密钥）。

6.2 故障排查

现象	检查点
<code>InitHsm</code> 返回 -1	芯片驱动是否加载 (<code>lsmod grep hed</code>), SPI/I2C 是否工作
<code>ConfigSSLWithHsm</code> 返回非 0	芯片内证书槽位是否为空 (生产烧录异常)
TLS 握手 "certificate verify failed"	Broker 证书是否由芯片内 kCA 签发, 时钟是否同步
paho 回调未触发	<code>privateKey</code> 是否为精确字符串 <code>"__EXTERNAL_CONFIG__"</code>
paho 走文件路径	<code>trustStore</code> / <code>keyStore</code> 不能与 <code>__EXTERNAL_CONFIG__</code> 混用

6.3 设备退役

1. 云端 KMS 吊销设备证书 → CRL/OCSP 生效
2. 安全芯片无需额外操作 (私钥永不出芯片, 物理报废即销毁)
3. 审计日志记录吊销操作

第七章：安全与合规

7.1 威胁模型

威胁	攻击面	防护
提取私钥	总线嗅探 (SPI/I2C)	芯片通信加密 + 私钥不出芯片
物理拆解	芯片开盖	防篡改自毁电路
侧信道	功耗/电磁分析	芯片硬件侧信道防护
替换芯片	更换安全芯片	芯片序列号 + KMS 白名单
重放攻击	重放总线命令	芯片内部计数器防重放

7.2 法规对齐

法规	要求	实现
ISO 21434	道路车辆网络安全	TARA 分析 + 安全芯片硬件信任根
WP.29 UN R155	车辆网络安全认证	OTA 证书更新 + 安全事件响应
国密 GM/T 0028	密码模块安全	CIU98B 通过国密二级认证
Common Criteria	安全芯片评估	EAL5+ 认证芯片

附录：技术指标与术语

A.1 技术指标

指标	值
RSA-2048 签名延迟	< 100 ms（芯片内运算）
安全存储容量	8 个证书/密钥槽位
通信接口	SPI (最高 10 Mbps)
工作温度	-40°C ~ +105°C
安全认证	国密二级 / CC EAL5+
防篡改	主动屏蔽层 + 电压/温度/频率异常检测

A.2 术语表

术语	说明
HSM	Hardware Security Module, 硬件安全模块（此处指独立安全芯片）
CIU98B	华大半导体安全芯片型号
libtbox_delivery.so	T-Box 交付库，封装 HSM 初始化 + 凭据注入
ConfigSSLWithHsm	将芯片内证书/私钥/CA 链注入 SSL_CTX 的函数
InitHsm	初始化安全芯片 + 加载 HSM ENGINE
kCA / kSubCert	芯片内 Root CA 和 Sub CA 证书槽位名
kDevicePrivateRsaKey	芯片内设备 RSA 私钥槽位名
__EXTERNAL_CONFIG__	paho 补丁中触发外部回调的标记字符串
SSLSocket_setExternalConfigCallback	paho 补丁新增的回调注册函数

A.3 与 OP-TEE 方案的对比

维度	HSM 安全芯片（本文档）	OP-TEE TA (21-product-manual)
安全硬件	独立安全芯片 (CIU98B)	ARM TrustZone + OP-TEE
密钥来源	芯片出厂烧录，不可更改	TEE 内 TEE_GenerateKey 生成
ENGINE	芯片厂商 HSM ENGINE	自研 e_tbox_keystore ENGINE

灌装方式	封测厂烧录 + 工厂验证	工厂工控机在线灌装
密钥轮换	不可（需更换芯片或 OTA 证书）	支持（unlock 后可 gen/delete）
并发	芯片内部串行化	OP-TEE 3.2 有限制，需 keyd 方案
物理防篡改	✔ 芯片硬件级	⚠ 依赖 SoC（TrustZone 无物理防护）
证书体系	Root → Sub → Device (CA 链)	Root CA → 各设备证书 (CA 链)

A.4 相关技术文档

- [19-hsm-chip-reference-architecture.md](#) — 他人 HSM 架构参考
- [21-product-manual.md](#) — OP-TEE 版产品说明书
- [18-mqtt-mutual-auth-demo.md](#) — MQTT 双向认证方案